Question_daochunhan

Question

靶机信息

- 靶机名称：Question
- 靶机作者：群主
- 靶机类型：Linux
- 来源：MazeSec/QQ公开群 321948805
- 官网：https://maze-sec.com/

user

端口扫描：

```
nmap -p- -Pn --min-rate 2000 192.168.64.87
```

```
┌─ daochunhan@astra ~
└─ ❯ nmap -p- -Pn --min-rate 2000 192.168.64.87
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 06:06 -0400
Nmap scan report for 192.168.64.87
Host is up (0.00052s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: AE:EF:20:EE:8F:6A (Unknown)

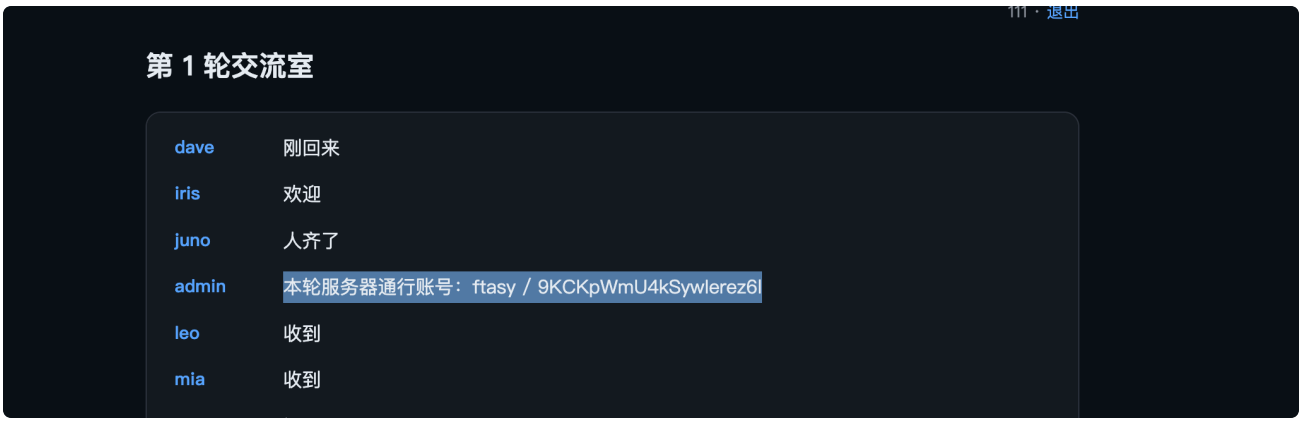
Nmap done: 1 IP address (1 host up) scanned in 20.29 seconds
```

```
22/tcp open  ssh
80/tcp open  http
```

80 端口是一个动态问答页面。

注册并登录站内账号，完成当前回合的加法题后进入房间，在房间消息中发现服务器账号：






```
ssh ftasy@192.168.64.87 # 9KCKpWmU4kSywIerez6l
```

```
daochunhan@astra ~
❯ ssh ftasy@192.168.64.87
ftasy@192.168.64.87's password:
Linux Question 7.2.7-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.2-12.2~trixie (2026-09-22) x86_64

                                HackMyVM

QQ Group:   321948805


ftasy@Question:~$ id
uid=1000(ftasy) gid=1000(ftasy) groups=1000(ftasy)
ftasy@Question:~$ cat user.txt
flag{user-2ac6adc7a0cd5c1b6cc08b555a21998c}
ftasy@Question:~$
```

查看 sudo：

```
sudo -l
cat /etc/passwd
```

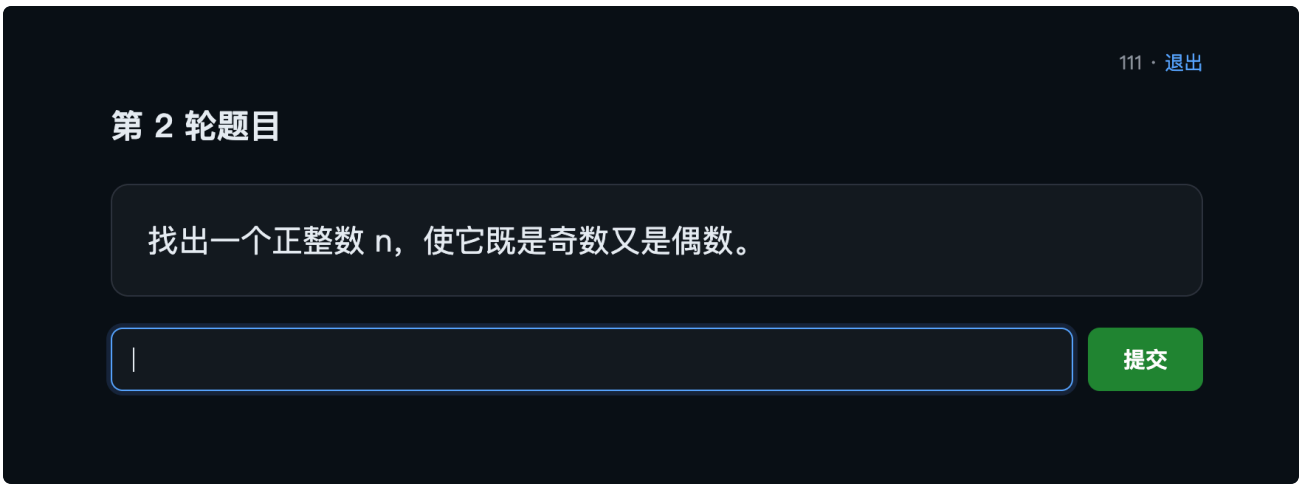
```
ftasy@Question:~$ sudo -l
Matching Defaults entries for ftasy on Question:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User ftasy may run the following commands on Question:
    (ALL) NOPASSWD: /usr/bin/whoami
ftasy@Question:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
ftasy:x:1000:1000::/home/ftasy:/bin/bash
oranger:x:1001:1001::/home/oranger:/bin/bash
ftasy@Question:~$
```

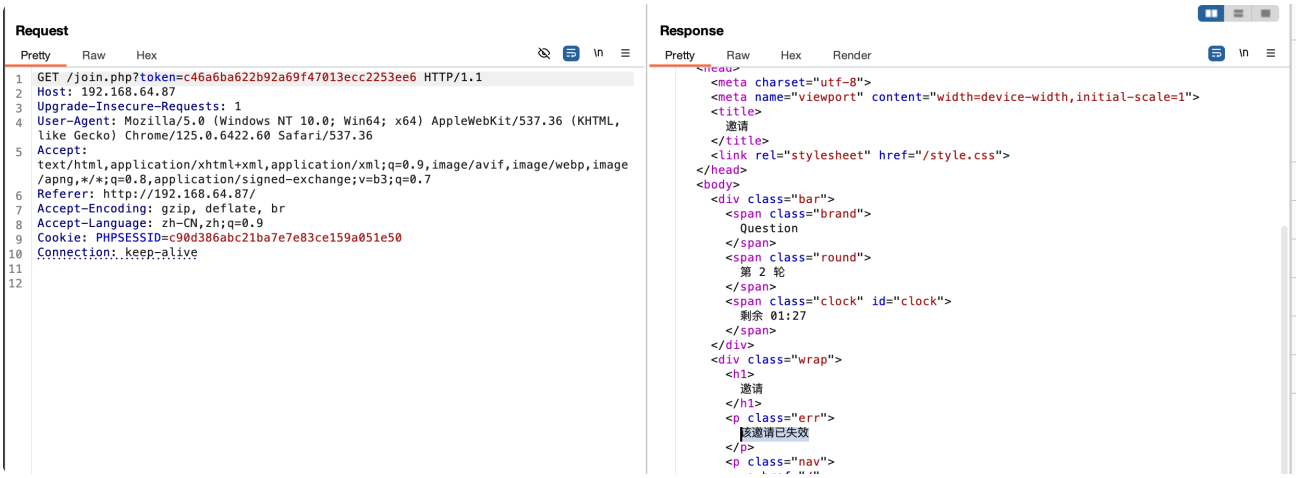
`whoami` 可以以 root 身份执行，查看 `/etc/passwd` 后发现可登录用户中还包含 `oranger`。

root

本地枚举没有发现其他线索，于是回到 80 端口的答题页面。偶数轮次都是悖论题，无法直接答对；奇数轮次可以进入聊天室，并且其中的聊天内容固定。因此考虑偶数轮次的聊天室可能泄漏了其他凭据线索：



尝试复用第一轮答题后获得的 Token，但邀请已经失效：



为了获取仍然有效的邀请，下一轮奇数轮次答题后保存生成的 Token：

```
/join.php?token=f0929ba9ad38f20363034ef0037ed040
```

等待当前轮次结束后再次访问，进入偶数轮次的聊天室：





在聊天室中发现另一组服务器凭据：

```
oranger / xdlhRx0c5S50nWNwtAjA
```

切换到 `oranger` 用户：

```
su oranger # xdlhRx0c5S50nWNwtAjA
```

```
ftasy@Question:~$ su oranger
Password:
oranger@Question:/home/ftasy$ id
uid=1001(oranger) gid=1001(oranger) groups=1001(oranger)
```

尝试将该密码复用到 `root`：

```
su root # xdlhRx0c5S50nWNwtAjA
```

```
oranger@Question:/home/ftasy$ su root
Password:
root@Question:/home/ftasy# id
uid=0(root) gid=0(root) groups=0(root)
root@Question:/home/ftasy# cat /root/root.txt
flag{root-2b7df8fefbf609bc162fae2f5e90c890}
root@Question:/home/ftasy#
```